Laboratorio: Análisis SCA local y en pipeline con Dependency-Check

Curso: PDDS — Trimestre 4 · **Universidad Galileo**

Estudiante: _____ · **Carné:** _____

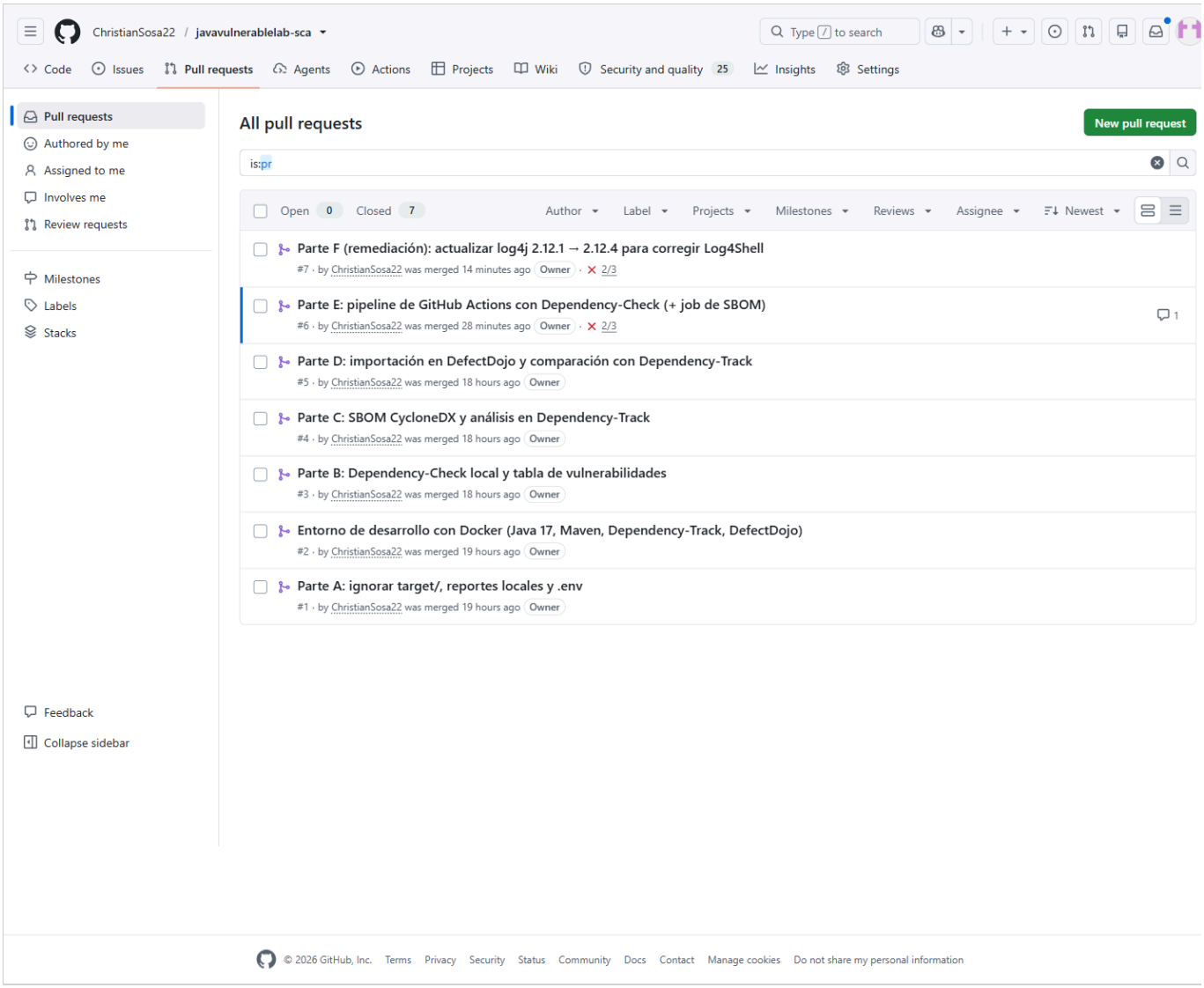
Fecha: 28 de octubre de 2026

Entregables

Entregable	Enlace
Repositorio público	https://github.com/ChristianSosa22/javavulnerablelab-sca
Workflow	`.github/workflows/sca-dependency-check.yml`
Pull Request de la remediación (Parte F del enunciado de entregables)	https://github.com/ChristianSosa22/javavulnerablelab-sca/pull/7
Pull Request de las preguntas de análisis	https://github.com/ChristianSosa22/javavulnerablelab-sca/pull/8
Reporte HTML de Dependency-Check (local)	`entregables/dependency-check-report.html`
SBOM CycloneDX	`entregables/bom.json`

El trabajo se organizó en un Pull Request por parte:

PR	Contenido
#1	Parte A: `.gitignore` (`target/`, reportes locales, `.env`)
#2	Entorno de desarrollo con Docker
#3	Parte B: Dependency-Check local y tabla de vulnerabilidades
#4	Parte C: SBOM y Dependency-Track
#5	Parte D: DefectDojo y comparación
#6	Parte E: pipeline de GitHub Actions
#7	Remediación de Log4Shell (log4j 2.12.1 → 2.12.4)
#8	Preguntas de análisis y este reporte



Entorno de trabajo

Todo el laboratorio corrió en Docker Desktop, sin instalar Java ni Maven en la máquina. `docker-compose.sca.yml` define:

- `maven:3.9-eclipse-temurin-17` (Java 17.0.20 + Maven 3.9.16) para Dependency-Check y CycloneDX, con un volumen persistente para `~/.m2`, donde queda la base del NVD.
- Dependency-Track 4.14.6 (`http://localhost:8080`).
- DefectDojo 3.4.300 (`http://localhost:8082`).

La clave del NVD se lee de un archivo `.env` ignorado por git. Detalle en `docs/ENTORNO.md`.

Parte A — Repositorio propio

1. Se clonó `CSPF-Founder/JavaVulnerableLab` y se eliminó su carpeta `.git`.
2. Se creó el repositorio público `javavulnerablelab-sca` con el código original en el primer commit.
3. Se agregaron al `.gitignore` `target/`, las carpetas de reportes locales y `.env` (PR #1).

> GitHub *push protection* bloqueó el primer push porque el laboratorio trae dos claves de Stripe **falsas** a propósito (reto de secretos expuestos). Se marcaron como "used in tests" para conservar el código original.

Dependencias declaradas en el `pom.xml`:

Dependencia	Versión	Alcance
junit:junit	3.8.1	test
mysql:mysql-connector-java	5.1.26	compile
org.json:json	20090211	compile
javax.servlet:jstl	1.2	compile
org.hibernate:hibernate-core	4.0.1.Final	compile
javax.servlet:servlet-api	2.3	provided
org.apache.logging.log4j:log4j-api	2.12.1	compile
org.apache.logging.log4j:log4j-core	2.12.1	compile
commons-collections:commons-collections	3.1	compile
commons-fileupload:commons-fileupload	1.3.3	compile
commons-io:commons-io	2.6	compile

Parte B — Dependency-Check en local

```
 docker compose -f docker-compose.sca.yml run --rm dependency-check
# mvn -B org.owasp:dependency-check-maven:13.0.0:check -Dformat=ALL
#     -DnvdApiKeyEnvironmentVariable=NVD_API_KEY -DossindexAnalyzerEnabled=false
```

La primera carga del NVD por la API tuvo errores y reintentos constantes (12 % en 35 minutos), así que la base se cargó una vez con los *data feeds* JSON 2.0 oficiales del NVD. Las ejecuciones siguientes usan la API con la clave y solo descargan cambios (49 s con 2 112 registros nuevos).

Windows PowerShell — Dependency-Check 13.0.0 (local, Docker)

```
PS C:\Users\xavis\Desktop\Universidad\PDDS\Trimestre 4\sca-tarea\javavulnerablelab-sca> docker compose -f docker-compose.sca.yml run --rm dependency-check
[INFO] Scanning for projects...
[INFO]
[INFO] ------------------< org.cysecurity:JavaVulnerableLab >------------------
[INFO] Building JavaVulnerableLab Maven Webapp 0.0.1-SNAPSHOT
[INFO]   from pom.xml
[INFO] --------------------------------[ war ]---------------------------------
[INFO]
[INFO] --- dependency-check:13.0.0:check (default-cli) @ JavaVulnerableLab ---
[INFO] Checking for updates
[INFO] Skipping the NVD API Update as it was completed within the last 240 minutes
[INFO] Should skip RetireJSDataSource update since last update was within period PT24H.
[INFO] Should skip HostedSuppressionsDataSource update since last update was within period PT2H.
[INFO] Skipping Known Exploited Vulnerabilities update check since last check was within 24 hours.
[INFO] Check for updates complete (24 ms)
[INFO]

Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the
tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysi
s or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arisin
g out of or in connection with the use of this tool, the analysis performed, or the resulting report.


   About ODC: https://dependency-check.github.io/DependencyCheck/general/internals.html
   False Positives: https://dependency-check.github.io/DependencyCheck/general/suppression.html


[INFO] Analysis Started
[INFO] Finished Archive Analyzer (0 seconds)
[INFO] Finished File Name Analyzer (0 seconds)
[INFO] Finished Jar Analyzer (0 seconds)
[INFO] Finished Dependency Merging Analyzer (0 seconds)
[INFO] Finished Hint Analyzer (0 seconds)
[INFO] Finished Version Filter Analyzer (0 seconds)
[INFO] Created CPE Index (2 seconds)
[INFO] Finished CPE Analyzer (3 seconds)
[INFO] Finished False Positive Analyzer (0 seconds)
[INFO] Finished NVD CVE Analyzer (0 seconds)
[INFO] Finished RetireJS Analyzer (0 seconds)
[WARNING] Sonatype OSS Index Analyzer disabled due to missing credentials. Authentication with token is now required, and OSS Index is migrating to Sonatype Guide. See https://depe
ndency-check.github.io/DependencyCheck/analyzers/oss-index-analyzer.html for more information on authentication with Sonatype Guide OSS Index.
[INFO] Finished Vulnerability Suppression Analyzer (0 seconds)
[INFO] Finished Known Exploited Vulnerability Analyzer (0 seconds)
[INFO] Finished Dependency Bundling Analyzer (0 seconds)
[INFO] Finished Unused Suppression Rule Analyzer (0 seconds)
[INFO] Analysis Complete (4 seconds)
[INFO] Writing XML report to: /src/target/dependency-check-report.xml
[INFO] Writing HTML report to: /src/target/dependency-check-report.html
[INFO] Writing JSON report to: /src/target/dependency-check-report.json
[INFO] Writing CSV report to: /src/target/dependency-check-report.csv
[INFO] Writing SARIF report to: /src/target/dependency-check-report.sarif
[INFO] Writing JENKINS report to: /src/target/dependency-check-jenkins.html
[INFO] Writing JUNIT report to: /src/target/dependency-check-junit.xml
[INFO] Writing GITLAB report to: /src/target/dependency-check-gitlab.json
[WARNING]

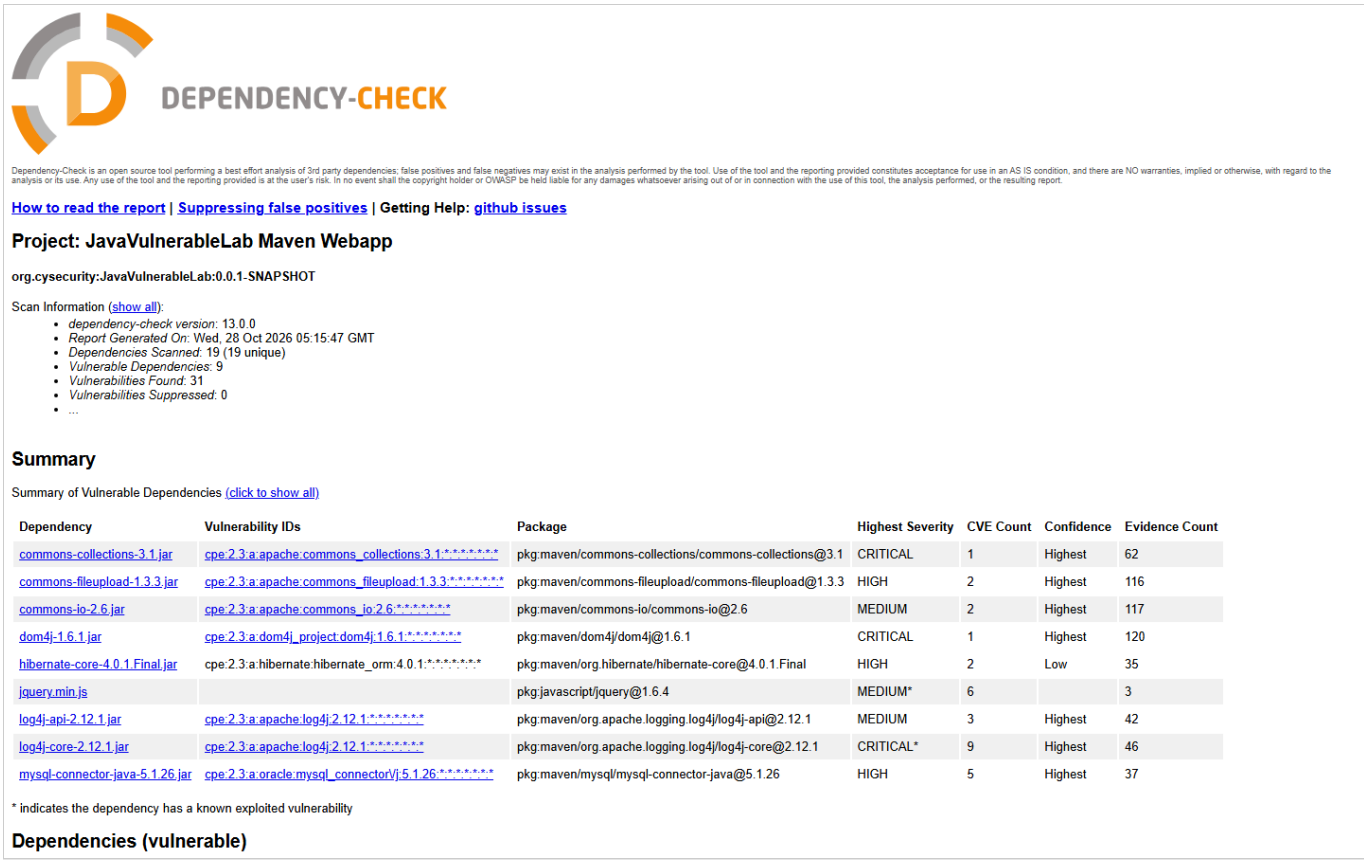
One or more dependencies were identified with known vulnerabilities in JavaVulnerableLab Maven Webapp:

commons-collections-3.1.jar (pkg:maven/commons-collections/commons-collections@3.1, cpe:2.3:a:apache:commons_collections:3.1:*:*:*:*:*:*:*) : CVE-2015-6420
commons-fileupload-1.3.3.jar (pkg:maven/commons-fileupload/commons-fileupload@1.3.3, cpe:2.3:a:apache:commons_fileupload:1.3.3:*:*:*:*:*:*:*) : CVE-2023-24998, CVE-2025-48976
commons-io-2.6.jar (pkg:maven/commons-io/commons-io@2.6, cpe:2.3:a:apache:commons_io:2.6:*:*:*:*:*:*:*) : CVE-2021-29425, CVE-2024-47554
dom4j-1.6.1.jar (pkg:maven/dom4j/dom4j@1.6.1, cpe:2.3:a:dom4j_project:dom4j:1.6.1:*:*:*:*:*:*:*) : CVE-2020-10683
hibernate-core-4.0.1.Final.jar (pkg:maven/org.hibernate/hibernate-core@4.0.1.Final, cpe:2.3:a:hibernate:hibernate_orm:4.0.1:*:*:*:*:*:*:*) : CVE-2020-25638, CVE-2019-14900
jquery.min.js (pkg:javascript/jquery@1.6.4) : CVE-2012-6708, CVE-2015-9251, CVE-2019-11358, CVE-2020-11023, CVE-2020-7656, jquery issue: 162
log4j-api-2.12.1.jar (pkg:maven/org.apache.logging.log4j/log4j-api@2.12.1, cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:*) : CVE-2026-34479, CVE-2026-34477, CVE-2020-9488
log4j-core-2.12.1.jar (pkg:maven/org.apache.logging.log4j/log4j-core@2.12.1, cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:*) : CVE-2021-44228, CVE-2021-45046, CVE-2026-34479, CVE-2026
-34480, CVE-2021-44832, CVE-2025-68161, CVE-2026-34477, CVE-2021-45105, CVE-2020-9488
mysql-connector-java-5.1.26.jar (pkg:maven/mysql/mysql-connector-java@5.1.26, cpe:2.3:a:oracle:mysql_connector\/j:5.1.26:*:*:*:*:*:*:*) : CVE-2023-22102, CVE-2019-2692, CVE-2020-29
34, CVE-2020-2875, CVE-2020-2933


See the dependency-check report for more details.


[INFO] ------------------------------------------------------------------------
[INFO] BUILD SUCCESS
[INFO] ------------------------------------------------------------------------
[INFO] Total time:  11.756 s
[INFO] Finished at: 2026-10-28T05:15:48Z
[INFO] ------------------------------------------------------------------------

PS C:\Users\xavis\Desktop\Universidad\PDDS\Trimestre 4\sca-tarea\javavulnerablelab-sca>
```



DEPENDENCY-CHECK

Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report.

How to read the report | Suppressing false positives | Getting Help: github issues

Project: JavaVulnerableLab Maven Webapp

org.cysecurity:JavaVulnerableLab:0.0.1-SNAPSHOT

Scan Information (show all):

- *dependency-check version*: 13.0.0
- *Report Generated On*: Wed, 28 Oct 2026 05:15:47 GMT
- *Dependencies Scanned*: 19 (19 unique)
- *Vulnerable Dependencies*: 9
- *Vulnerabilities Found*: 31
- *Vulnerabilities Suppressed*: 0
- ...

Summary

Summary of Vulnerable Dependencies (click to show all)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
commons-collections-3.1.jar	cpe:2.3:a:apache:commons_collections:3.1:*:*:*:*:*:*:*	pkg:maven/commons-collections/commons-collections@3.1	CRITICAL	1	Highest	62
commons-fileupload-1.3.3.jar	cpe:2.3:a:apache:commons_fileupload:1.3.3:*:*:*:*:*:*:*	pkg:maven/commons-fileupload/commons-fileupload@1.3.3	HIGH	2	Highest	116
commons-io-2.6.jar	cpe:2.3:a:apache:commons_io:2.6:*:*:*:*:*:*:*	pkg:maven/commons-io/commons-io@2.6	MEDIUM	2	Highest	117
dom4j-1.6.1.jar	cpe:2.3:a:dom4j_project:dom4j:1.6.1:*:*:*:*:*:*:*	pkg:maven/dom4j/dom4j@1.6.1	CRITICAL	1	Highest	120
hibernate-core-4.0.1.Final.jar	cpe:2.3:a:hibernate:hibernate_orm:4.0.1:*:*:*:*:*:*:*	pkg:maven/org.hibernate/hibernate-core@4.0.1.Final	HIGH	2	Low	35
jquery.min.js		pkg:javascript/jquery@1.6.4	MEDIUM*	6		3
log4j-api-2.12.1.jar	cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-api@2.12.1	MEDIUM	3	Highest	42
log4j-core-2.12.1.jar	cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-core@2.12.1	CRITICAL*	9	Highest	46
mysql-connector-java-5.1.26.jar	cpe:2.3:a:oracle:mysql_connector\/j:5.1.26:*:*:*:*:*:*:*	pkg:maven/mysql/mysql-connector-java@5.1.26	HIGH	5	Highest	37

* indicates the dependency has a known exploited vulnerability

Dependencies (vulnerable)

Resultado: 19 dependencias analizadas, **9 vulnerables, 31 vulnerabilidades** (4 Critical, 7 High, 16 Medium, 4 Low).

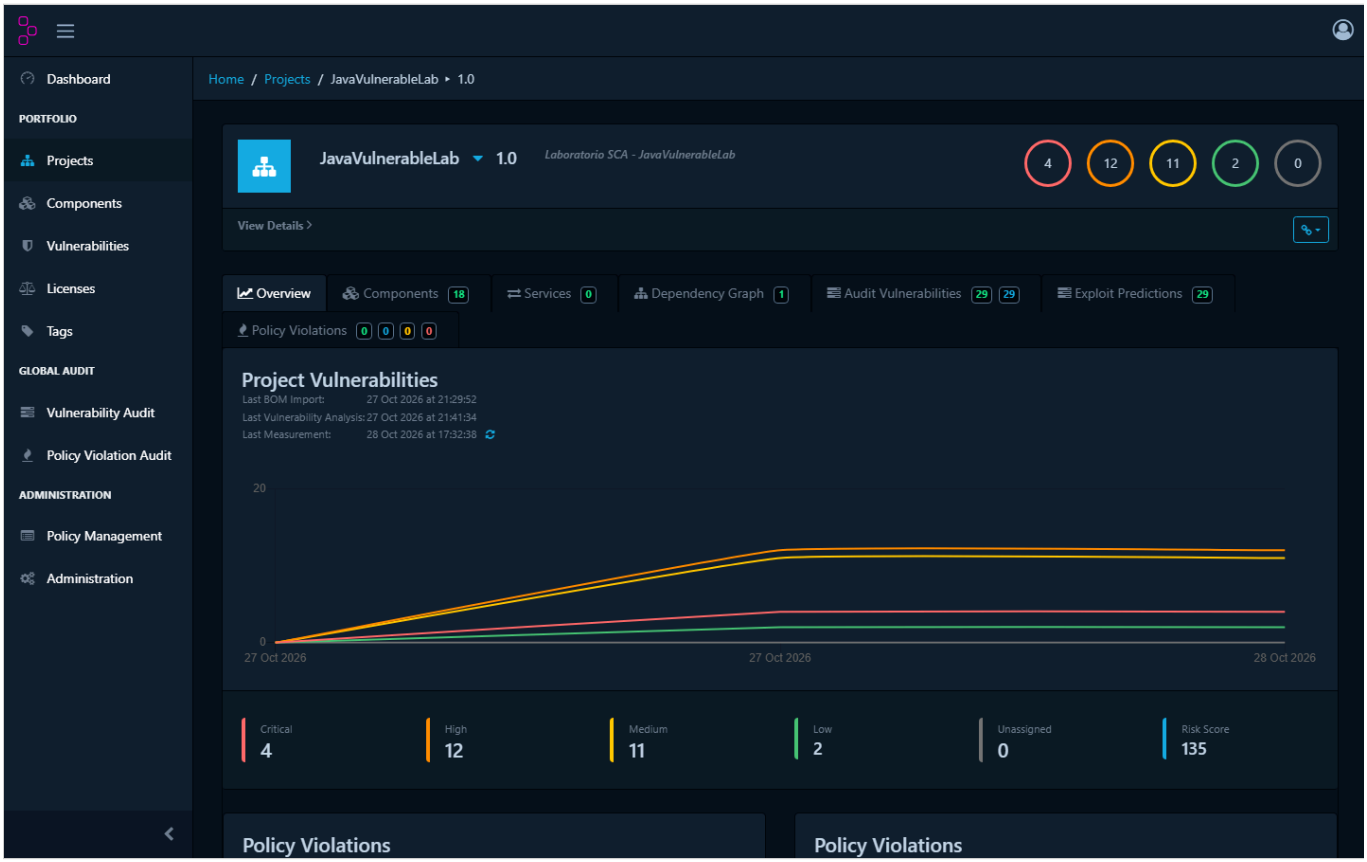
Dependencia	Vulnerabilidades	Más grave
log4j-core 2.12.1	9	**CVE-2021-44228 Log4Shell (10.0)**, CVE-2021-45046 (9.0)
commons-collections 3.1	1	CVE-2015-6420 (9.8)
dom4j 1.6.1 *(transitiva)*	1	CVE-2020-10683 (9.8)
mysql-connector-java 5.1.26	5	CVE-2023-22102 (8.3)
commons-fileupload 1.3.3	2	CVE-2023-24998, CVE-2025-48976 (7.5)
hibernate-core 4.0.1.Final	2	CVE-2020-25638 (7.4)
log4j-api 2.12.1	3	CVE-2026-34479 (7.5)
jquery.min.js 1.6.4	6	CVE-2012-6708 y otras (6.1)
commons-io 2.6	2	CVE-2021-29425 (4.8)

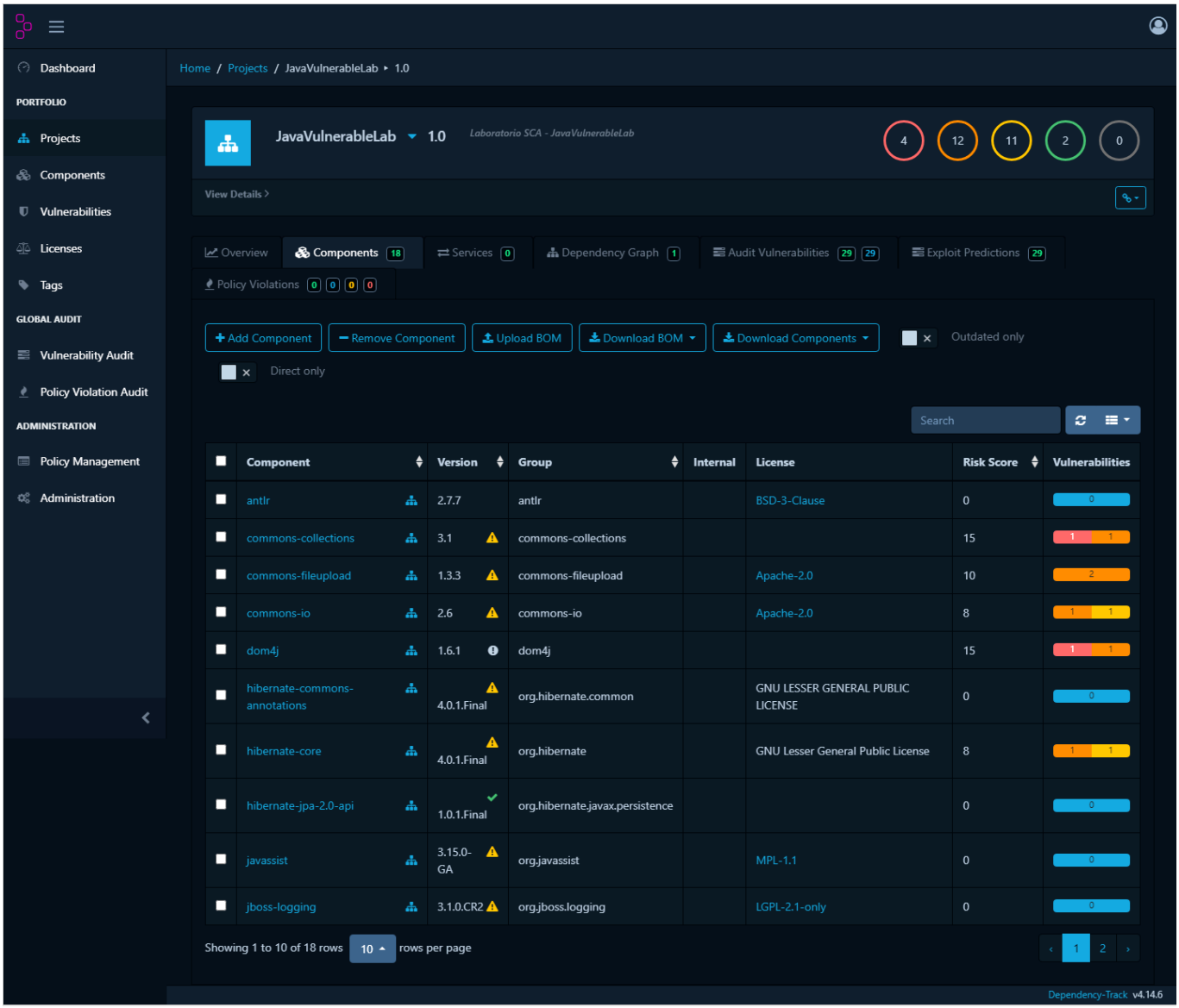
La tabla completa con los 31 CVE está en `docs/parte-b-dependency-check.md`.

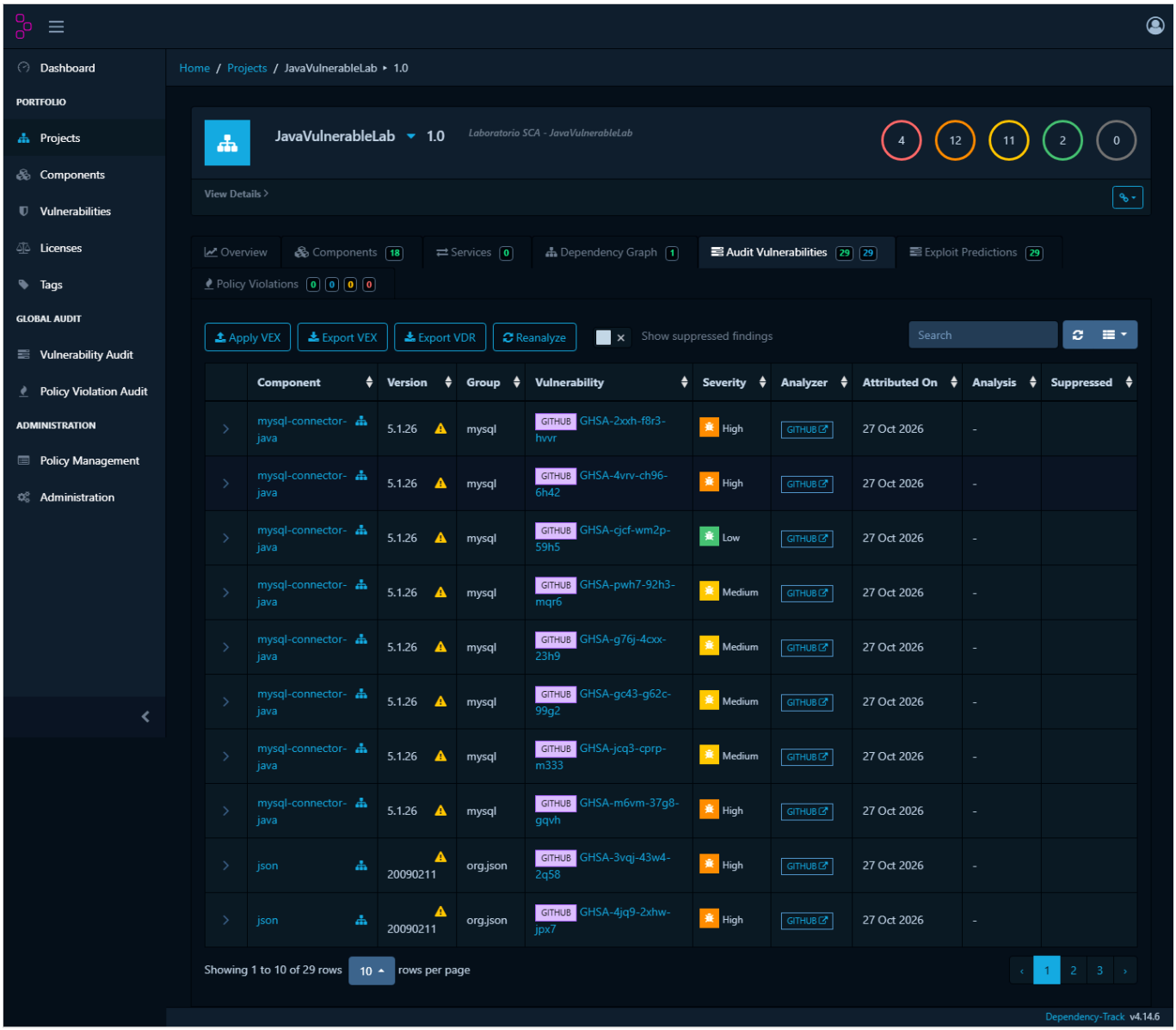
Parte C — SBOM y Dependency-Track

- SBOM con `cyclonedx-maven-plugin:2.9.3:makeAggregateBom` (CycloneDX 1.6 JSON): **18 componentes**, 10 directos y 8 transitivos de `hibernate-core` (`junit` se excluye por ser de `test`).

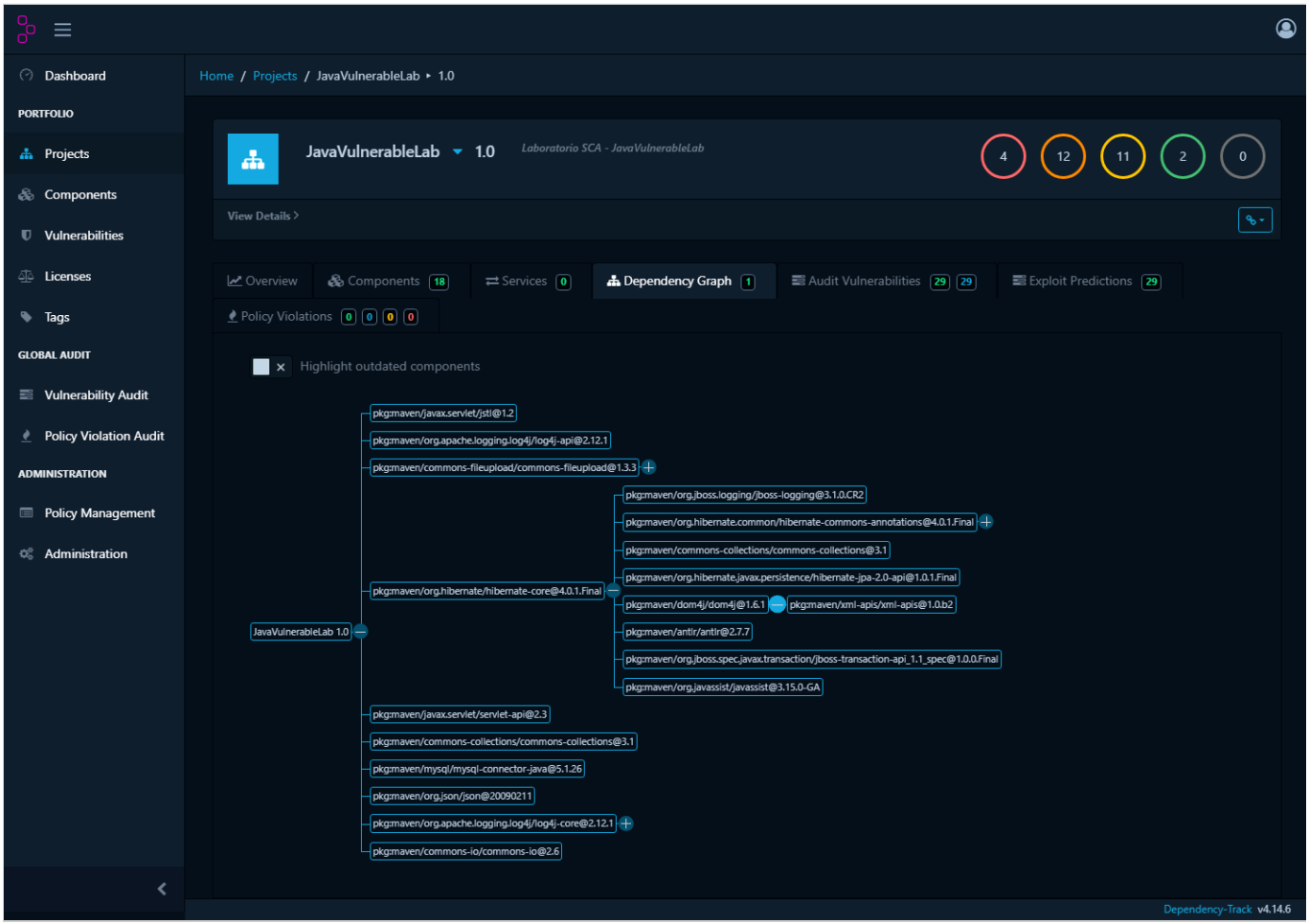
- Proyecto **JavaVulnerableLab 1.0** en Dependency-Track con la fuente **OSV (Maven)** activada: **29 vulnerabilidades** (4 Critical, 12 High, 11 Medium, 2 Low).




Dashboard
PORTFOLIO
Projects
Components
Vulnerabilities
Licenses
Tags
GLOBAL AUDIT
Vulnerability Audit
Policy Violation Audit
ADMINISTRATION
Policy Management
Administration
Home / Projects / JavaVulnerableLab ▸ 1.0
JavaVulnerableLab 1.0
Laboratorio SCA - JavaVulnerableLab
4
12
11
2
0
View Details
Overview
Components 18
Services 0
Dependency Graph 1
Audit Vulnerabilities 29 29
Exploit Predictions 29
Policy Violations 0 0 0 0
+ Add Component
− Remove Component
Upload BOM
Download BOM
Download Components
Outdated only
Direct only
Search
Component
Version
Group
Internal
License
Risk Score
Vulnerabilities
antlr 2.7.7 antlr BSD-3-Clause 0
commons-collections 3.1 commons-collections 15
commons-fileupload 1.3.3 commons-fileupload Apache-2.0 10
commons-io 2.6 commons-io Apache-2.0 8
dom4j 1.6.1 dom4j 15
hibernate-commons-annotations 4.0.1.Final org.hibernate.common GNU LESSER GENERAL PUBLIC LICENSE 0
hibernate-core 4.0.1.Final org.hibernate GNU Lesser General Public License 8
hibernate-jpa-2.0-api 1.0.1.Final org.hibernate.javax.persistence 0
javassist 3.15.0-GA org.javassist MPL-1.1 0
jboss-logging 3.1.0.CR2 org.jboss.logging LGPL-2.1-only 0
Showing 1 to 10 of 18 rows 10 rows per page
1 2
Dependency-Track v4.14.6


Dashboard
PORTFOLIO
Projects
Components
Vulnerabilities
Licenses
Tags
GLOBAL AUDIT
Vulnerability Audit
Policy Violation Audit
ADMINISTRATION
Policy Management
Administration
Home / Projects / JavaVulnerableLab ▸ 1.0
JavaVulnerableLab 1.0
Laboratorio SCA - JavaVulnerableLab
4
12
11
2
0
View Details
Overview
Components 18
Services 0
Dependency Graph 1
Audit Vulnerabilities 29 29
Exploit Predictions 29
Policy Violations 0 0 0 0
Apply VEX
Export VEX
Export VDR
Reanalyze
Show suppressed findings
Search
Component
Version
Group
Vulnerability
Severity
Analyzer
Attributed On
Analysis
Suppressed
mysql-connector-java
5.1.26
mysql
GITHUB GHSA-2xxh-f8r3-hvvr
High
GITHUB
27 Oct 2026
-
mysql-connector-java
5.1.26
mysql
GITHUB GHSA-4vrv-ch96-6h42
High
GITHUB
27 Oct 2026
-
mysql-connector-java
5.1.26
mysql
GITHUB GHSA-cjcf-wm2p-59h5
Low
GITHUB
27 Oct 2026
-
mysql-connector-java
5.1.26
mysql
GITHUB GHSA-pwh7-92h3-mqr6
Medium
GITHUB
27 Oct 2026
-
mysql-connector-java
5.1.26
mysql
GITHUB GHSA-g76j-4cxx-23h9
Medium
GITHUB
27 Oct 2026
-
mysql-connector-java
5.1.26
mysql
GITHUB GHSA-gc43-g62c-99g2
Medium
GITHUB
27 Oct 2026
-
mysql-connector-java
5.1.26
mysql
GITHUB GHSA-jcq3-cprp-m333
Medium
GITHUB
27 Oct 2026
-
mysql-connector-java
5.1.26
mysql
GITHUB GHSA-m6vm-37g8-gqvh
High
GITHUB
27 Oct 2026
-
json
20090211
org.json
GITHUB GHSA-3vqj-43w4-2q58
High
GITHUB
27 Oct 2026
-
json
20090211
org.json
GITHUB GHSA-4jq9-2xhw-jpx7
High
GITHUB
27 Oct 2026
-
Showing 1 to 10 of 29 rows
10
rows per page
1
2
3
Dependency-Track v4.14.6

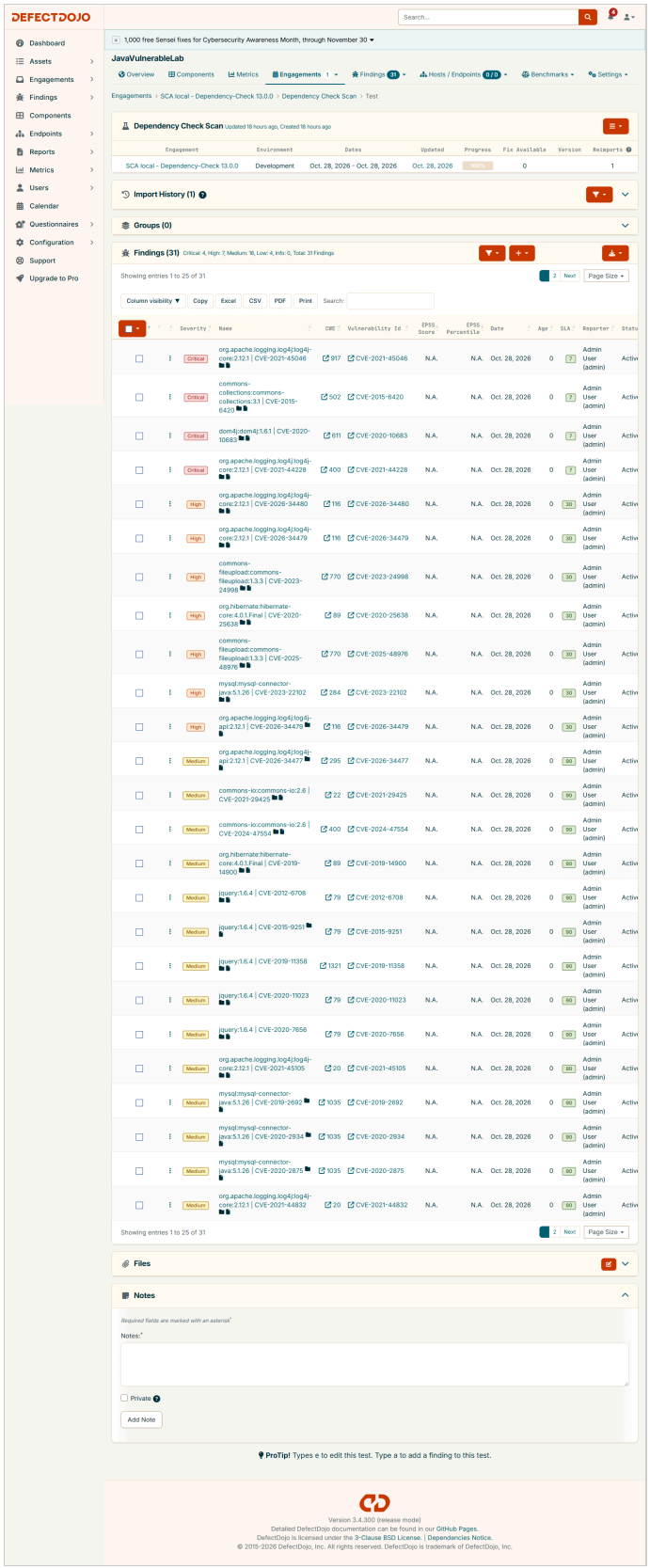
Dependency Graph: origen de una transitiva vulnerable

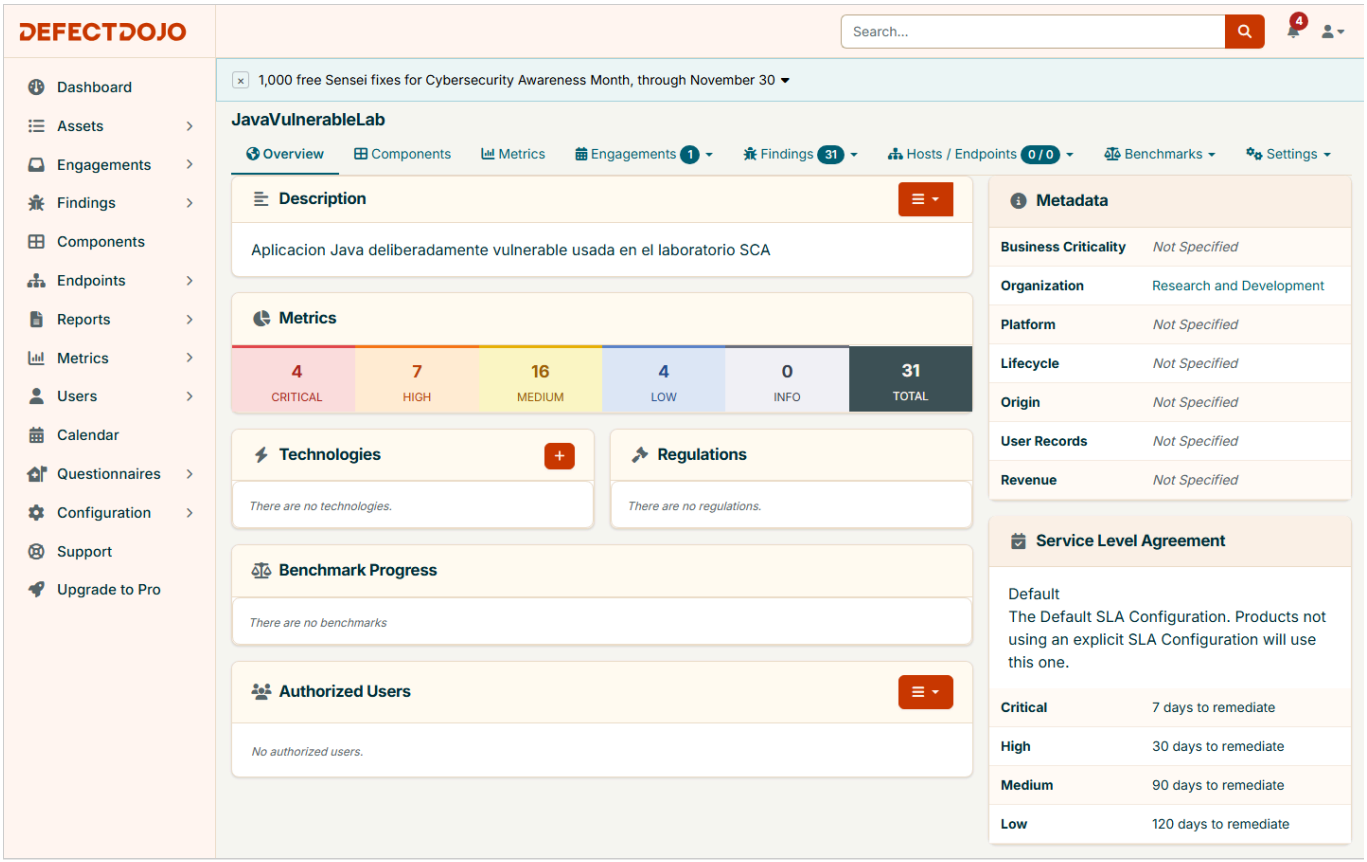


`dom4j 1.6.1` **no está declarada** en el `pom.xml`: llega porque `hibernate-core 4.0.1.Final` la necesita (`JavaVulnerableLab → hibernate-core → dom4j → xml-apis`). Tiene **CVE-2020-10683** (XXE, 9.8) y **CVE-2018-1000632** (inyección XML). El grafo también muestra que `commons-collections 3.1` llega tanto directa como transitivamente (Hibernate), así que quitarla del `pom.xml` no la eliminaría del WAR.

Parte D — DefectDojo y comparación

Producto **JavaVulnerableLab**, importación de `dependency-check-report.xml` con el tipo **Dependency Check Scan**: **31 hallazgos** (4 Critical, 7 High, 16 Medium, 4 Low).


DEFECTDOJO
Search...
Dashboard
Assets
Engagements
Findings
Components
Endpoints
Reports
Metrics
Users
Calendar
Questionnaires
Configuration
Support
Upgrade to Pro
1,000 free Sensei fixes for Cybersecurity Awareness Month, through November 30
JavaVulnerableLab
Overview
Components
Metrics
Engagements 1
Findings 31
Hosts / Endpoints 0 / 0
Benchmarks
Settings
Engagements › SCA local - Dependency-Check 13.0.0 › Dependency Check Scan › Test
Dependency Check Scan Updated 18 hours ago, Created 18 hours ago
Engagement | Environment | Dates | Updated | Progress | Fix Available | Version | Reimports
SCA local - Dependency-Check 13.0.0 | Development | Oct. 28, 2026 - Oct. 28, 2026 | Oct. 28, 2026 | 100% | 0 | | 1
Import History (1)
Groups (0)
Findings (31) Critical: 4, High: 7, Medium: 16, Low: 4, Info: 0, Total: 31 Findings
Showing entries 1 to 25 of 31
Column visibility
Copy
Excel
CSV
PDF
Print
Search:
Severity | Name | CWE | Vulnerability Id | EPSS Score | EPSS Percentile | Date | Age | SLA | Reporter | Statu
org.apache.logging.log4j:log4j-core:2.12.1 | CVE-2021-45046 | 917 | CVE-2021-45046 | N.A. | N.A. | Oct. 28, 2026 | 0 | 7 | Admin User (admin)
commons-collections:commons-collections:3.1 | CVE-2015-6420 | 502 | CVE-2015-6420 | N.A. | N.A. | Oct. 28, 2026 | 0 | 7 | Admin User (admin)
dom4j:dom4j:1.6.1 | CVE-2020-10683 | 611 | CVE-2020-10683 | N.A. | N.A. | Oct. 28, 2026 | 0 | 7 | Admin User (admin)
org.apache.logging.log4j:log4j-core:2.12.1 | CVE-2021-44228 | 400 | CVE-2021-44228 | N.A. | N.A. | Oct. 28, 2026 | 0 | 7 | Admin User (admin)
org.apache.logging.log4j:log4j-core:2.12.1 | CVE-2026-34480 | 116 | CVE-2026-34480 | N.A. | N.A. | Oct. 28, 2026 | 0 | 30 | Admin User (admin)
org.apache.logging.log4j:log4j-core:2.12.1 | CVE-2026-34479 | 116 | CVE-2026-34479 | N.A. | N.A. | Oct. 28, 2026 | 0 | 30 | Admin User (admin)
commons-fileupload:commons-fileupload:1.3.3 | CVE-2023-24998 | 770 | CVE-2023-24998 | N.A. | N.A. | Oct. 28, 2026 | 0 | 30 | Admin User (admin)
org.hibernate:hibernate-core:4.0.1.Final | CVE-2020-25638 | 89 | CVE-2020-25638 | N.A. | N.A. | Oct. 28, 2026 | 0 | 30 | Admin User (admin)
commons-fileupload:commons-fileupload:1.3.3 | CVE-2025-48976 | 770 | CVE-2025-48976 | N.A. | N.A. | Oct. 28, 2026 | 0 | 30 | Admin User (admin)
mysql:mysql-connector-java:5.1.26 | CVE-2023-22102 | 284 | CVE-2023-22102 | N.A. | N.A. | Oct. 28, 2026 | 0 | 30 | Admin User (admin)
org.apache.logging.log4j:log4j-api:2.12.1 | CVE-2026-34479 | 116 | CVE-2026-34479 | N.A. | N.A. | Oct. 28, 2026 | 0 | 30 | Admin User (admin)
org.apache.logging.log4j:log4j-api:2.12.1 | CVE-2026-34477 | 295 | CVE-2026-34477 | N.A. | N.A. | Oct. 28, 2026 | 0 | 60 | Admin User (admin)
commons-io:commons-io:2.6 | CVE-2021-29425 | 22 | CVE-2021-29425 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
commons-io:commons-io:2.6 | CVE-2024-47554 | 400 | CVE-2024-47554 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
org.hibernate:hibernate-core:4.0.1.Final | CVE-2019-14900 | 89 | CVE-2019-14900 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
jquery:1.6.4 | CVE-2012-6708 | 79 | CVE-2012-6708 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
jquery:1.6.4 | CVE-2015-9251 | 79 | CVE-2015-9251 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
jquery:1.6.4 | CVE-2019-11358 | 1321 | CVE-2019-11358 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
jquery:1.6.4 | CVE-2020-11023 | 79 | CVE-2020-11023 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
jquery:1.6.4 | CVE-2020-7656 | 79 | CVE-2020-7656 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
org.apache.logging.log4j:log4j-core:2.12.1 | CVE-2021-45105 | 20 | CVE-2021-45105 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
mysql:mysql-connector-java:5.1.26 | CVE-2019-2692 | 1035 | CVE-2019-2692 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
mysql:mysql-connector-java:5.1.26 | CVE-2020-2934 | 1035 | CVE-2020-2934 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
mysql:mysql-connector-java:5.1.26 | CVE-2020-2875 | 1035 | CVE-2020-2875 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
org.apache.logging.log4j:log4j-core:2.12.1 | CVE-2021-44832 | 20 | CVE-2021-44832 | N.A. | N.A. | Oct. 28, 2026 | 0 | 90 | Admin User (admin)
Showing entries 1 to 25 of 31
Page Size
Files
Notes
Required fields are marked with an asterisk*
Notes:*
Private
Add Note
ProTip! Types e to edit this test. Type a to add a finding to this test.
Version 3.4.300 (release mode)
Detailed DefectDojo documentation can be found in our GitHub Pages.
DefectDojo is licensed under the 3-Clause BSD License. | Dependencies Notice.
© 2015-2026 DefectDojo, Inc. All rights reserved. DefectDojo is trademark of DefectDojo, Inc.



Comparación

	Dependency-Check / DefectDojo	Dependency-Track
Identificación	CPE inferido por evidencia	PURL exacto del SBOM
Fuentes	NVD, CISA KEV, RetireJS	NVD + OSV (GitHub Advisories)
Componentes vulnerables	9	8
Hallazgos	31	29
Pares componente+CVE en común	19	19
Solo en esta herramienta	12	10

¿Coinciden? En lo importante sí: 7 componentes son vulnerables en ambas, y las dos detectan Log4Shell, las críticas de `dom4j` y de `commons-collections`, y los mismos 9 CVE de `log4j-core`.

¿Una encontró lo que la otra no? Sí:

- **Solo Dependency-Check:** `jquery.min.js` (6, archivo JS que no está en el SBOM de Maven), `log4j-api` (3, comparte el CPE `apache:log4j` con core: probables falsos positivos) y 3 CVE de `mysql-connector-java`.
- **Solo Dependency-Track:** `org.json 20090211` (2, el CPE del NVD no coincide con el JAR: falso negativo de Dependency-Check), CVE-2015-7501 (crítica) en `commons-collections`, CVE-2018-1000632 en `dom4j` y 6 CVE de MySQL que vienen de avisos GHSA.

¿Por qué? Por identificación distinta (CPE vs PURL), fuentes distintas (NVD vs OSV/GHSA), alcance distinto (archivos del proyecto vs dependencias del SBOM) y momentos de actualización distintos. Detalle en `docs/parte-d-defectdojo.md`.

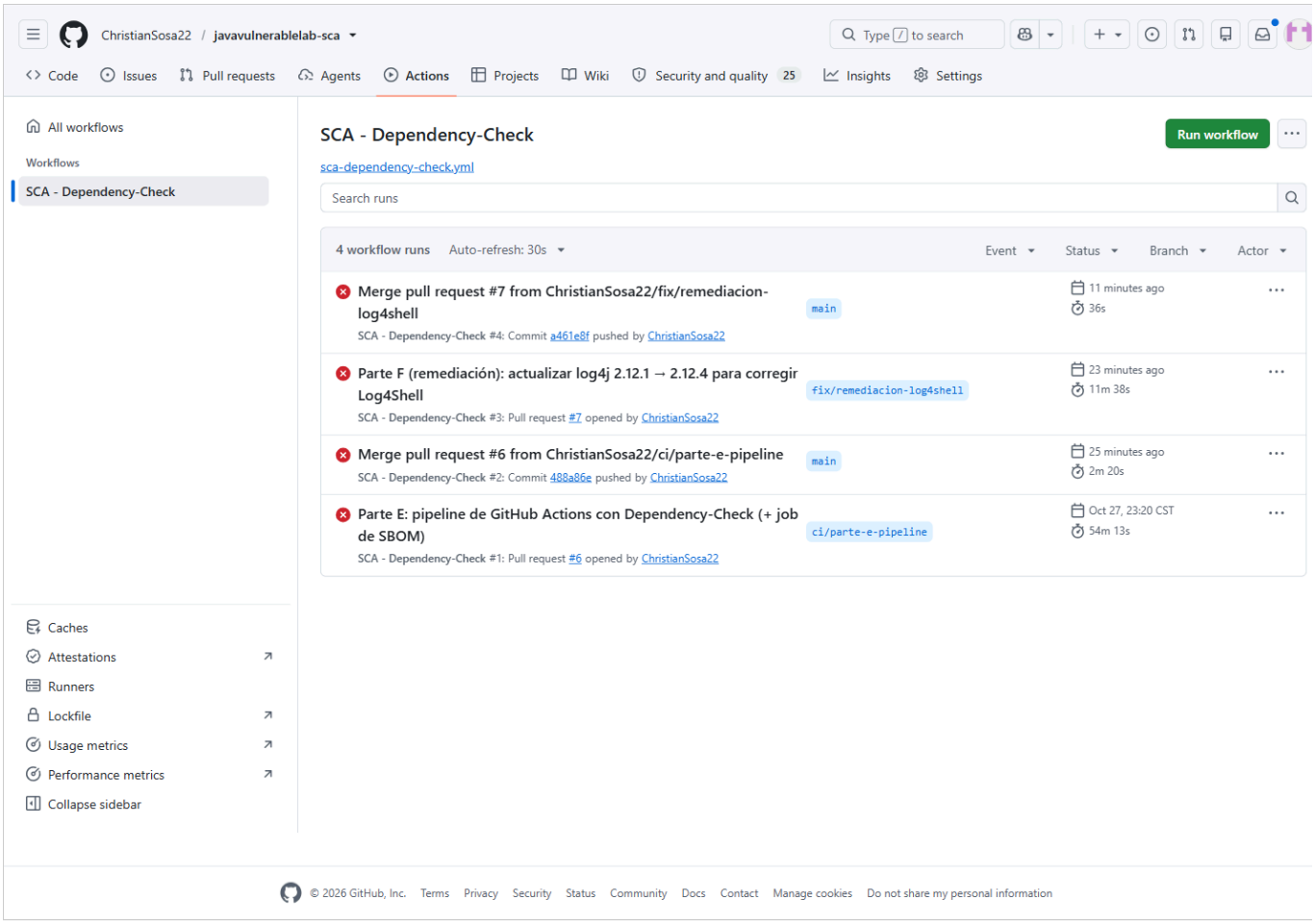
Parte E — Pipeline con Dependency-Check

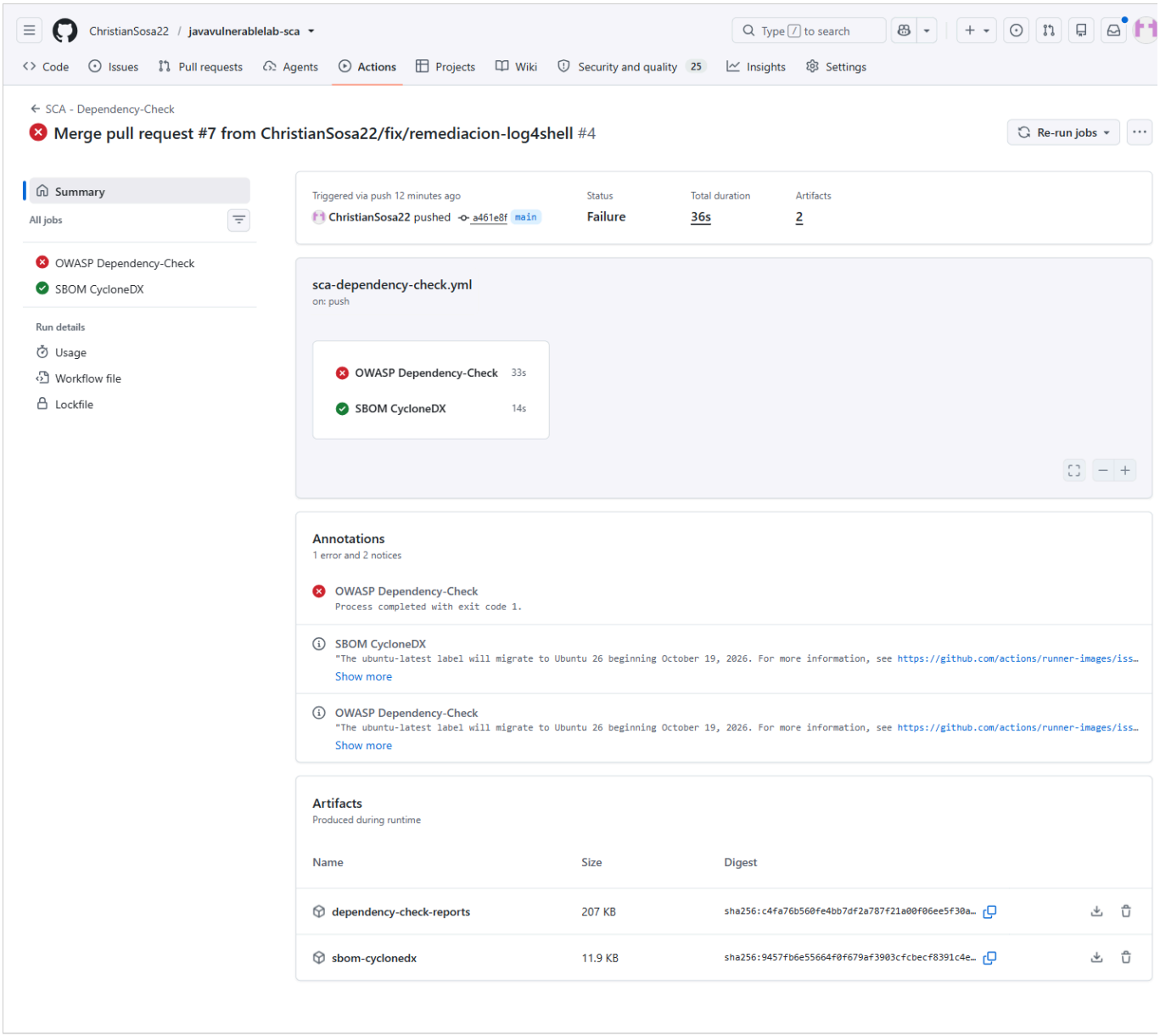
Archivo `.github/workflows/sca-dependency-check.yml` (todas las líneas comentadas).

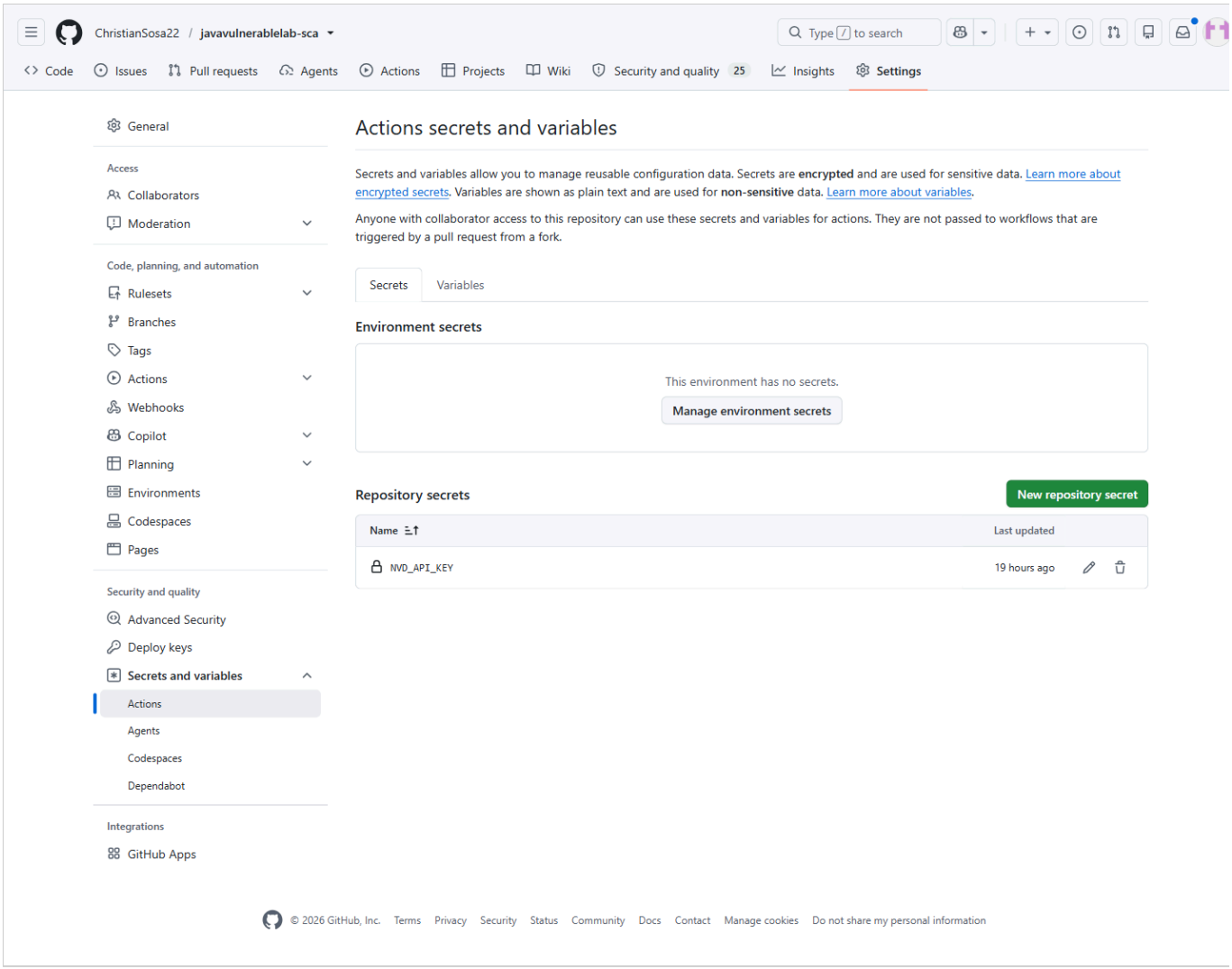
#	Requisito	Implementación
1	Disparadores	`push` y `pull_request` a `main`, `workflow_dispatch`
2	Permisos mínimos	`contents: read`, `security-events: write`
3	Java 17	`actions/setup-java@v6` (Temurin 17)
4	Secreto	`NVD_API_KEY` → `${{ secrets.NVD_API_KEY }}` como variable de entorno, leída con `-DnvdApiKey EnvironmentVariable`
5	Caché del NVD	`actions/cache/restore` + `actions/cache/save` con `if: always()` sobre `~/.m2/repository/org/owasp/dependency-check-data` y clave diaria
6	Formatos	`-Dformats=HTML,XML,JSON,SARIF`
7	Code scanning	`github/codeql-action/upload-sarif@v4`, `category: dependency-check`
8	Artefactos	`dependency-check-reports` (HTML, XML, JSON, SARIF)
9	Comentarios	Cada línea del YAML lleva comentario
Extra	SBOM	Job `sbom` → artefacto `sbom-cyclonedx`

Decisiones:

- **Puerta de seguridad** `failBuildOnCVSS=7`: el job falla si hay vulnerabilidades High o Critical. Los pasos de publicación usan `if: always()`, así el SARIF y los reportes se suben igual. En este proyecto, vulnerable a propósito, el job queda en rojo incluso después de la remediación.
- **Caché separada en restore/save** porque `actions/cache` solo guarda si el job termina bien, y aquí el análisis falla a propósito. La primera ejecución tardó 54 min en construir la base; las siguientes, unos 2 min.
- **Carga inicial sin caché** desde los *data feeds* oficiales del NVD (solo si no se restauró ninguna caché); después las actualizaciones van por la API con la clave.


ChristianSosa22 / javavulnerablelab-sca
Type / to search
Code
Issues
Pull requests
Agents
Actions
Projects
Wiki
Security and quality 25
Insights
Settings
All workflows
Workflows
SCA - Dependency-Check
SCA - Dependency-Check
Run workflow
sca-dependency-check.yml
Search runs
4 workflow runs
Auto-refresh: 30s
Event
Status
Branch
Actor
Merge pull request #7 from ChristianSosa22/fix/remediacion-log4shell
main
SCA - Dependency-Check #4: Commit a461e8f pushed by ChristianSosa22
11 minutes ago
36s
Parte F (remediación): actualizar log4j 2.12.1 → 2.12.4 para corregir Log4Shell
fix/remediacion-log4shell
SCA - Dependency-Check #3: Pull request #7 opened by ChristianSosa22
23 minutes ago
11m 38s
Merge pull request #6 from ChristianSosa22/ci/parte-e-pipeline
main
SCA - Dependency-Check #2: Commit 488a86e pushed by ChristianSosa22
25 minutes ago
2m 20s
Parte E: pipeline de GitHub Actions con Dependency-Check (+ job de SBOM)
ci/parte-e-pipeline
SCA - Dependency-Check #1: Pull request #6 opened by ChristianSosa22
Oct 27, 23:20 CST
54m 13s
Caches
Attestations
Runners
Lockfile
Usage metrics
Performance metrics
Collapse sidebar
© 2026 GitHub, Inc.
Terms
Privacy
Security
Status
Community
Docs
Contact
Manage cookies
Do not share my personal information

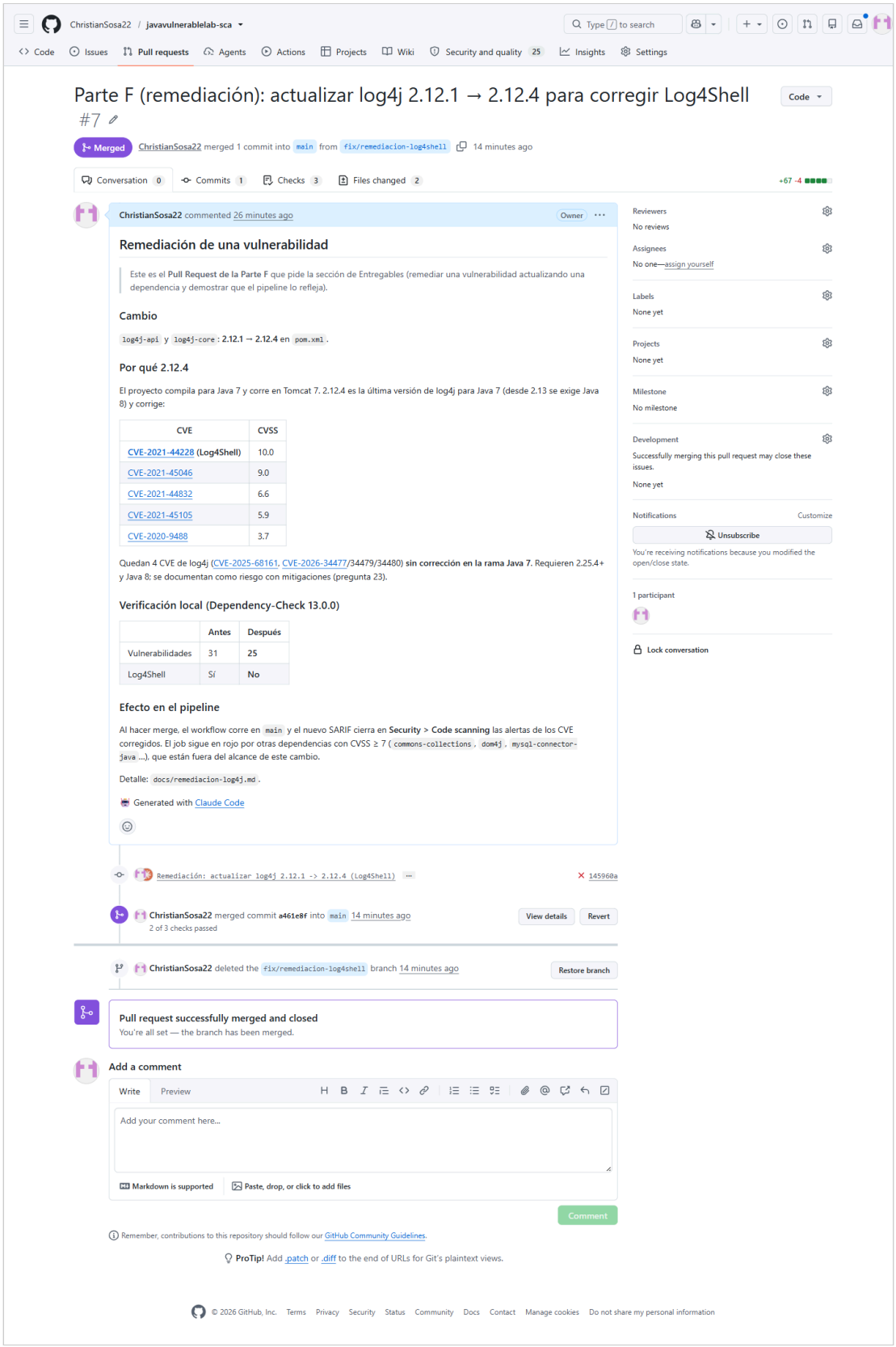

ChristianSosa22 / javavulnerablelab-sca
Type / to search
Code
Issues
Pull requests
Agents
Actions
Projects
Wiki
Security and quality 25
Insights
Settings
SCA - Dependency-Check
Merge pull request #7 from ChristianSosa22/fix/remediacion-log4shell #4
Re-run jobs
Summary
All jobs
OWASP Dependency-Check
SBOM CycloneDX
Run details
Usage
Workflow file
Lockfile
Triggered via push 12 minutes ago
ChristianSosa22 pushed a461e8f main
Status
Failure
Total duration
36s
Artifacts
2
sca-dependency-check.yml
on: push
OWASP Dependency-Check 33s
SBOM CycloneDX 14s
Annotations
1 error and 2 notices
OWASP Dependency-Check
Process completed with exit code 1.
SBOM CycloneDX
"The ubuntu-latest label will migrate to Ubuntu 26 beginning October 19, 2026. For more information, see https://github.com/actions/runner-images/iss…
Show more
OWASP Dependency-Check
"The ubuntu-latest label will migrate to Ubuntu 26 beginning October 19, 2026. For more information, see https://github.com/actions/runner-images/iss…
Show more
Artifacts
Produced during runtime
Name
Size
Digest
dependency-check-reports
207 KB
sha256:c4fa76b560fe4bb7df2a787f21a00f06ee5f30a…
sbom-cyclonedx
11.9 KB
sha256:9457fb6e55664f0f679af3903cfcbecf8391c4e…



Explicación completa en docs/parte-e-pipeline.md.

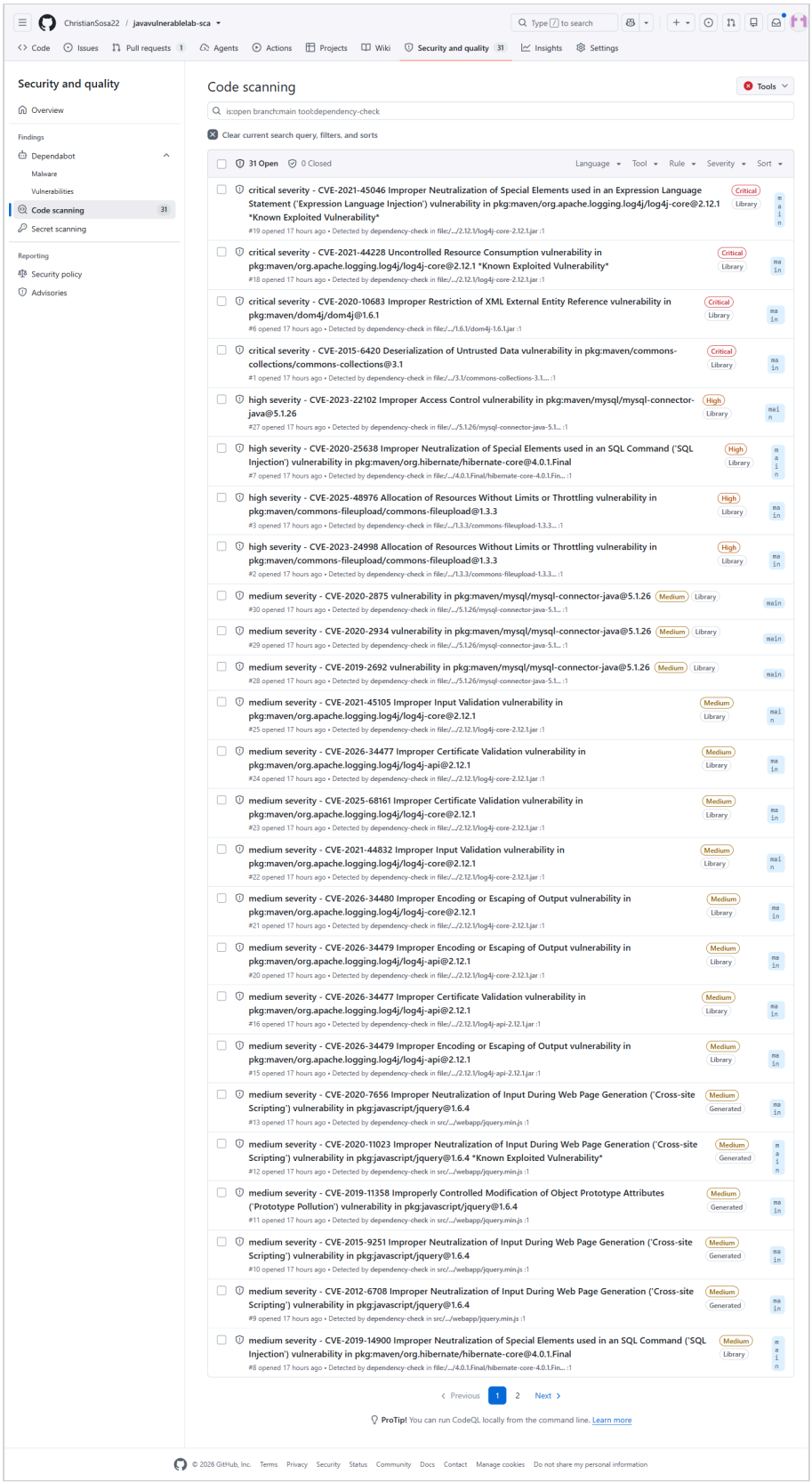
Remediación (PR #7)

`log4j-api` y `log4j-core` **2.12.1 → 2.12.4**. La aplicación corre en Java 7 / Tomcat 7, y 2.12.4 es la última versión de log4j para Java 7 (desde 2.13 se exige Java 8). Corrige **CVE-2021-44228 (Log4Shell)**, CVE-2021-45046, CVE-2021-45105, CVE-2021-44832 y CVE-2020-9488.

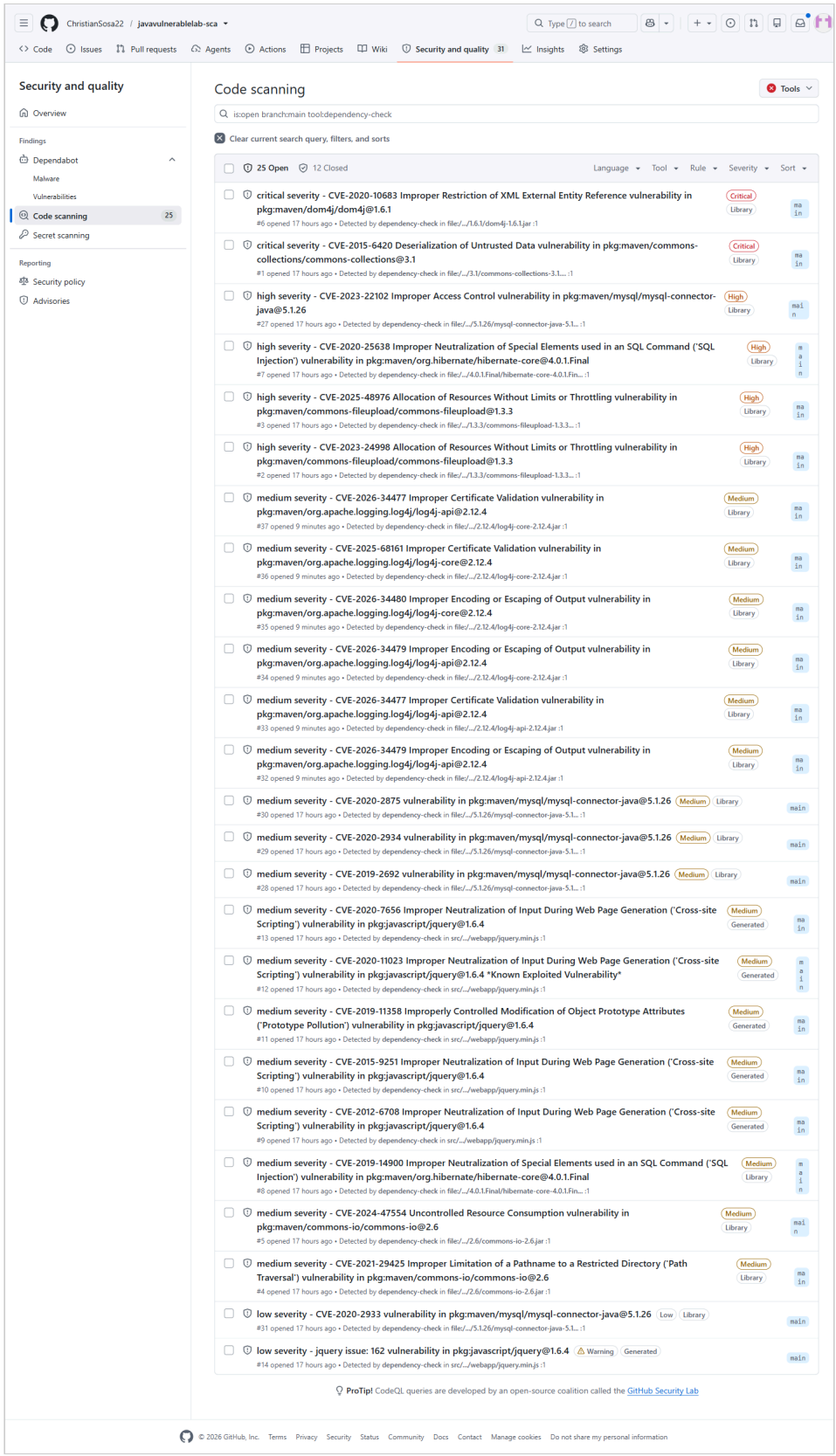


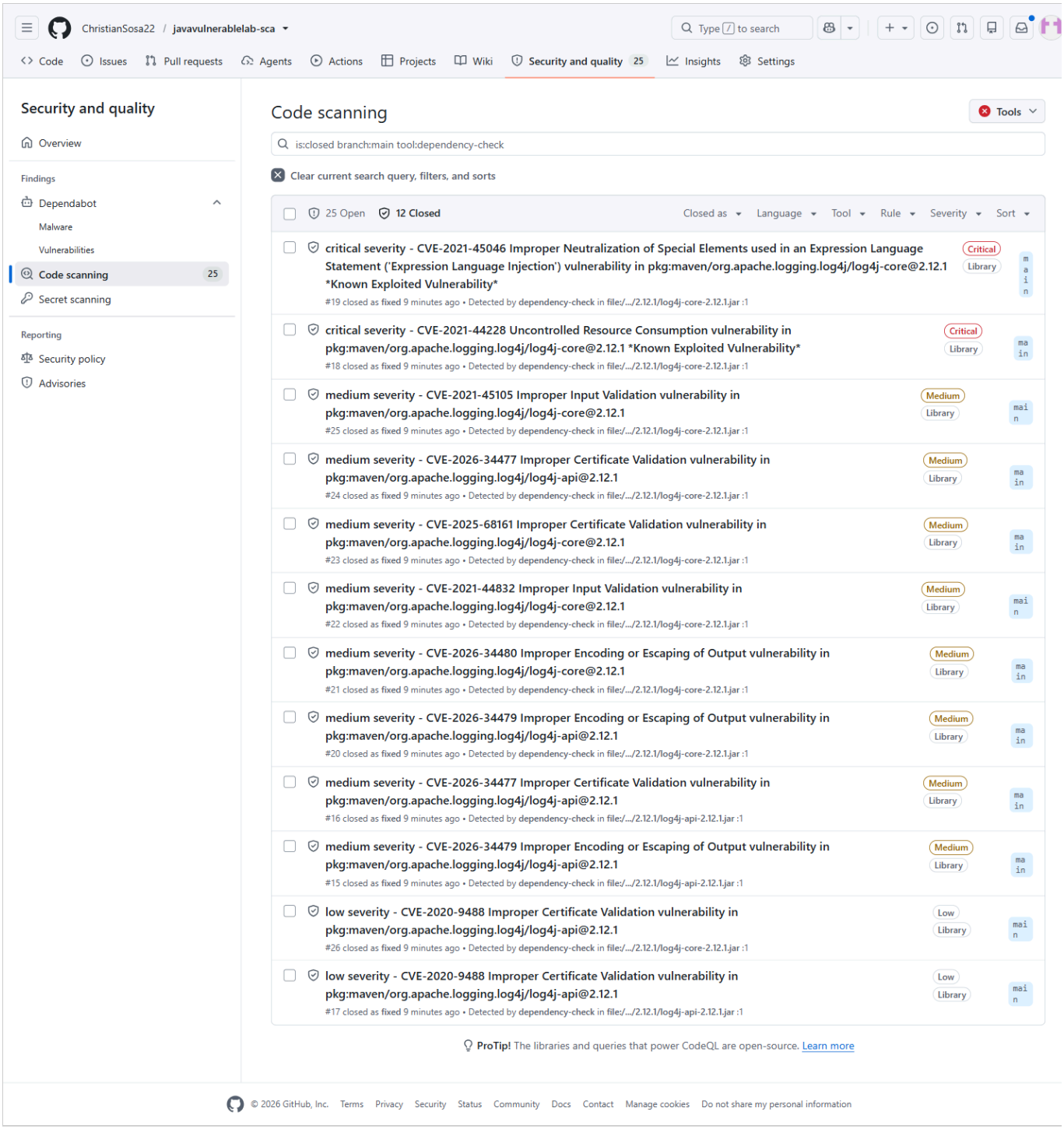
Code scanning antes y después

Antes: 31 alertas abiertas, con Log4Shell y CVE-2021-45046 como *Critical*.



Después: 25 alertas abiertas y 12 cerradas como *Fixed*, entre ellas **CVE-2021-44228** y CVE-2021-45046.


ChristianSosa22 / javavulnerablelab-sca
Type / to search
Code
Issues
Pull requests
Agents
Actions
Projects
Wiki
Security and quality 31
Insights
Settings
Security and quality
Overview
Findings
Dependabot
Malware
Vulnerabilities
Code scanning 25
Secret scanning
Reporting
Security policy
Advisories
Code scanning
Tools
is:open branch:main tool:dependency-check
Clear current search query, filters, and sorts
25 Open
12 Closed
Language
Tool
Rule
Severity
Sort
critical severity - CVE-2020-10683 Improper Restriction of XML External Entity Reference vulnerability in pkg:maven/dom4j/dom4j@1.6.1
#6 opened 17 hours ago • Detected by dependency-check in file/.../1.6.1/dom4j-1.6.1.jar :1
Critical
Library
critical severity - CVE-2015-6420 Deserialization of Untrusted Data vulnerability in pkg:maven/commons-collections/commons-collections@3.1
#1 opened 17 hours ago • Detected by dependency-check in file/.../3.1/commons-collections-3.1... :1
Critical
Library
high severity - CVE-2023-22102 Improper Access Control vulnerability in pkg:maven/mysql/mysql-connector-java@5.1.26
#27 opened 17 hours ago • Detected by dependency-check in file/.../5.1.26/mysql-connector-java-5.1... :1
High
Library
high severity - CVE-2020-25638 Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in pkg:maven/org.hibernate/hibernate-core@4.0.1.Final
#7 opened 17 hours ago • Detected by dependency-check in file/.../4.0.1.Final/hibernate-core-4.0.1.Fin... :1
High
Library
high severity - CVE-2025-48976 Allocation of Resources Without Limits or Throttling vulnerability in pkg:maven/commons-fileupload/commons-fileupload@1.3.3
#3 opened 17 hours ago • Detected by dependency-check in file/.../1.3.3/commons-fileupload-1.3.3... :1
High
Library
high severity - CVE-2023-24998 Allocation of Resources Without Limits or Throttling vulnerability in pkg:maven/commons-fileupload/commons-fileupload@1.3.3
#2 opened 17 hours ago • Detected by dependency-check in file/.../1.3.3/commons-fileupload-1.3.3... :1
High
Library
medium severity - CVE-2026-34477 Improper Certificate Validation vulnerability in pkg:maven/org.apache.logging.log4j/log4j-api@2.12.4
#37 opened 9 minutes ago • Detected by dependency-check in file/.../2.12.4/log4j-core-2.12.4.jar :1
Medium
Library
medium severity - CVE-2025-68161 Improper Certificate Validation vulnerability in pkg:maven/org.apache.logging.log4j/log4j-core@2.12.4
#36 opened 9 minutes ago • Detected by dependency-check in file/.../2.12.4/log4j-core-2.12.4.jar :1
Medium
Library
medium severity - CVE-2026-34480 Improper Encoding or Escaping of Output vulnerability in pkg:maven/org.apache.logging.log4j/log4j-core@2.12.4
#35 opened 9 minutes ago • Detected by dependency-check in file/.../2.12.4/log4j-core-2.12.4.jar :1
Medium
Library
medium severity - CVE-2026-34479 Improper Encoding or Escaping of Output vulnerability in pkg:maven/org.apache.logging.log4j/log4j-api@2.12.4
#34 opened 9 minutes ago • Detected by dependency-check in file/.../2.12.4/log4j-core-2.12.4.jar :1
Medium
Library
medium severity - CVE-2026-34477 Improper Certificate Validation vulnerability in pkg:maven/org.apache.logging.log4j/log4j-api@2.12.4
#33 opened 9 minutes ago • Detected by dependency-check in file/.../2.12.4/log4j-api-2.12.4.jar :1
Medium
Library
medium severity - CVE-2026-34479 Improper Encoding or Escaping of Output vulnerability in pkg:maven/org.apache.logging.log4j/log4j-api@2.12.4
#32 opened 9 minutes ago • Detected by dependency-check in file/.../2.12.4/log4j-api-2.12.4.jar :1
Medium
Library
medium severity - CVE-2020-2875 vulnerability in pkg:maven/mysql/mysql-connector-java@5.1.26
#30 opened 17 hours ago • Detected by dependency-check in file/.../5.1.26/mysql-connector-java-5.1... :1
Medium
Library
main
medium severity - CVE-2020-2934 vulnerability in pkg:maven/mysql/mysql-connector-java@5.1.26
#29 opened 17 hours ago • Detected by dependency-check in file/.../5.1.26/mysql-connector-java-5.1... :1
Medium
Library
main
medium severity - CVE-2019-2692 vulnerability in pkg:maven/mysql/mysql-connector-java@5.1.26
#28 opened 17 hours ago • Detected by dependency-check in file/.../5.1.26/mysql-connector-java-5.1... :1
Medium
Library
main
medium severity - CVE-2020-7656 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in pkg:javascript/jquery@1.6.4
#13 opened 17 hours ago • Detected by dependency-check in src/.../webapp/jquery.min.js :1
Medium
Generated
medium severity - CVE-2020-11023 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in pkg:javascript/jquery@1.6.4 *Known Exploited Vulnerability*
#12 opened 17 hours ago • Detected by dependency-check in src/.../webapp/jquery.min.js :1
Medium
Generated
medium severity - CVE-2019-11358 Improperly Controlled Modification of Object Prototype Attributes ('Prototype Pollution') vulnerability in pkg:javascript/jquery@1.6.4
#11 opened 17 hours ago • Detected by dependency-check in src/.../webapp/jquery.min.js :1
Medium
Generated
medium severity - CVE-2015-9251 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in pkg:javascript/jquery@1.6.4
#10 opened 17 hours ago • Detected by dependency-check in src/.../webapp/jquery.min.js :1
Medium
Generated
medium severity - CVE-2012-6708 Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in pkg:javascript/jquery@1.6.4
#9 opened 17 hours ago • Detected by dependency-check in src/.../webapp/jquery.min.js :1
Medium
Generated
medium severity - CVE-2019-14900 Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in pkg:maven/org.hibernate/hibernate-core@4.0.1.Final
#8 opened 17 hours ago • Detected by dependency-check in file/.../4.0.1.Final/hibernate-core-4.0.1.Fin... :1
Medium
Library
medium severity - CVE-2024-47554 Uncontrolled Resource Consumption vulnerability in pkg:maven/commons-io/commons-io@2.6
#5 opened 17 hours ago • Detected by dependency-check in file/.../2.6/commons-io-2.6.jar :1
Medium
Library
medium severity - CVE-2021-29425 Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability in pkg:maven/commons-io/commons-io@2.6
#4 opened 17 hours ago • Detected by dependency-check in file/.../2.6/commons-io-2.6.jar :1
Medium
Library
low severity - CVE-2020-2933 vulnerability in pkg:maven/mysql/mysql-connector-java@5.1.26
#31 opened 17 hours ago • Detected by dependency-check in file/.../5.1.26/mysql-connector-java-5.1... :1
Low
Library
main
low severity - jquery issue: 162 vulnerability in pkg:javascript/jquery@1.6.4
#14 opened 17 hours ago • Detected by dependency-check in src/.../webapp/jquery.min.js :1
Warning
Generated
main
ProTip! CodeQL queries are developed by an open-source coalition called the GitHub Security Lab
© 2026 GitHub, Inc.
Terms
Privacy
Security
Status
Community
Docs
Contact
Manage cookies
Do not share my personal information



GitHub identifica cada alerta por regla (CVE) **y ubicación** (el JAR). Al cambiar `log4j-core-2.12.1.jar` por `log4j-core-2.12.4.jar`, se cierran las 12 alertas del JAR viejo y se abren 6 nuevas en el JAR nuevo para los 4 CVE que **no tienen corrección en la rama Java 7** (CVE-2025-68161, CVE-2026-34477, CVE-2026-34479, CVE-2026-34480): 31 − 12 + 6 = 25. Esos CVE requieren log4j 2.25.4+ (Java 8) y se gestionan como riesgo aceptado con mitigaciones (ver pregunta 23).

Preguntas de análisis

19. ¿Qué diferencia hay entre SAST y SCA? ¿Por qué una aplicación necesita ambos?

SAST analiza el **código propio**: busca patrones inseguros como inyección SQL, XSS o deserialización sin validar, y señala la línea exacta del problema (por ejemplo, Semgrep). **SCA** analiza el **código de terceros**: identifica cada librería directa y transitiva (nombre, versión, CPE o PURL) y la cruza con bases de vulnerabilidades conocidas (NVD, OSV, GitHub Advisories). También sirve para revisar licencias.

Se necesitan ambos porque cubren superficies distintas. En JavaVulnerableLab, SAST encuentra la inyección SQL de las páginas JSP, pero no puede saber que `log4j-core 2.12.1` es vulnerable a Log4Shell, porque ese código no está en el repositorio. SCA encuentra Log4Shell, pero no ve la inyección SQL escrita a mano. La mayor parte del código que se ejecuta en una aplicación moderna viene de dependencias, y a la vez una aplicación con todas sus dependencias al día puede seguir siendo vulnerable por su propio código.

20. ¿Qué es una dependencia transitiva y por qué es difícil de controlar? Ejemplo del proyecto

Es una librería que el proyecto **no declara**, pero que llega porque una dependencia directa la necesita; Maven la resuelve y la empaqueta en el WAR. Es difícil de controlar porque no aparece en el `pom.xml` (hay que usar `mvn dependency:tree` o un SBOM para verla), su versión la decide el autor de la dependencia directa, el árbol puede ser profundo y la misma librería puede llegar por varios caminos, y actualizarla obliga a subir la directa (puede romper la API) o a forzar la versión con `<dependencyManagement>` (puede romper la directa).

Ejemplo: el `pom.xml` solo declara `hibernate-core 4.0.1.Final`, que trae `dom4j 1.6.1` con **CVE-2020-10683** (XXE, 9.8) y CVE-2018-1000632. El Dependency Graph muestra `JavaVulnerableLab → hibernate-core → dom4j`. Corregirlo exige subir Hibernate a una versión que use `org.dom4j:dom4j 2.1.3+` o forzar esa versión y probar que Hibernate 4.0 siga funcionando.

21. ¿Qué ventaja tiene Dependency-Track (monitoreo continuo del SBOM) frente a ejecutar Dependency-Check solo en el pipeline?

El pipeline es una **foto puntual**: solo analiza cuando hay push o PR. Si se publica un CVE nuevo y el repositorio no recibe cambios en un mes, nadie se entera durante ese mes. Dependency-Track guarda el SBOM de cada versión desplegada y lo **reevalúa continuamente** cada vez que actualiza sus fuentes, sin recompilar. Además ofrece alertas automáticas (correo, Slack, webhooks), un inventario de toda la organización ("¿qué proyectos usan log4j 2.12.1?", clave durante Log4Shell), auditoría con supresiones justificadas, métricas históricas, políticas de licencias y seguridad, y EPSS para priorizar. Lo ideal es combinar ambos: Dependency-Check como **puerta** en el pipeline y Dependency-Track como **monitoreo** de lo desplegado.

22. ¿Por qué Dependency-Check y Dependency-Track pueden reportar resultados distintos para el mismo proyecto?

1. **Identificación:** Dependency-Check infiere el CPE a partir de la evidencia del JAR (nombre, manifiesto, `pom.properties`), lo que produce falsos positivos (`log4j-api` con CVE de core) y falsos negativos (`org.jso`

`n`). Dependency-Track usa el PURL exacto del SBOM.
2. **Fuentes:** NVD (+ KEV, RetireJS) frente a NVD + OSV/GitHub Advisories, cada una con su cobertura y sus rangos de versiones (CVE-2015-7501 solo aparece por GHSA).
3. **Alcance:** Dependency-Check analiza también archivos como `jquery.min.js`; el SBOM de Maven solo describe dependencias Maven.
4. **Momento de actualización** de cada base local.
5. **Configuración:** analizadores desactivados (OSS Index), supresiones y deduplicación de alias (CVE ↔ GHSA).

23. Si una librería vulnerable no tiene versión corregida, ¿qué alternativas hay para gestionar el riesgo?

1. **Analizar si el código vulnerable es alcanzable** y, si no lo es, documentarlo y suprimir el hallazgo con justificación (supresión de Dependency-Check, estado *Not Affected* o VEX en Dependency-Track).
2. **Reemplazar** la librería por una alternativa mantenida, o **excluirla** (`<exclusions>`) si es transitiva y no se usa.
3. **Mitigar por configuración:** en log4j, no usar `XmlLayout`, `Log4j1XmlLayout` ni el Socket Appender con TLS (los 4 CVE que quedaron sin corrección en 2.12.4), o en su momento `-Dlog4j2.formatMsgNoLookups=true` para Log4Shell.
4. **Parchear o hacer *fork*** y publicar una versión interna corregida.
5. **Controles compensatorios:** WAF o RASP, validación de entrada, segmentación de red, mínimo privilegio y monitoreo de explotación.
6. **Aceptar el riesgo formalmente** con responsable, fecha de revisión y severidad real (CVSS + EPSS + exposición), y planificar la migración (aquí: pasar a Java 8 y log4j 2.25.4+). Dependency-Track avisa automáticamente cuando sale una versión corregida.